Informe de Incidente de Seguridad

Vulnerabilidad de Inyección SQL en DVWA

1. Introducción

El presente informe documenta la explotación de una vulnerabilidad de **Inyección SQL (SQL Injection)** identificada en la aplicación **Damn Vulnerable Web Application (DVWA)**, utilizada con fines educativos para el análisis de fallos de seguridad en aplicaciones web.

El objetivo del ejercicio fue demostrar cómo una validación incorrecta de entradas permite a un atacante manipular consultas SQL y acceder a información sensible sin autorización.

2. Descripción del Incidente

La vulnerabilidad se encuentra en el módulo **SQL Injection** de DVWA.
La aplicación acepta un parámetro de entrada (*User ID*) que es concatenado directamente en una consulta SQL sin sanitización adecuada.

Esto permite que un atacante inserte código SQL malicioso y modifique el comportamiento original de la consulta.

3. Proceso de Reproducción

Se accedió a la aplicación DVWA desde la máquina virtual:

```
http://localhost/DVWA
```

1. Se inició sesión con las credenciales por defecto:
    - **Usuario:** admin
    - **Contraseña:** password
2. Se configuró el nivel de seguridad en **Low**.
3. Se ingresó al módulo **SQL Injection**.

En el campo *User ID* se introdujo la siguiente entrada maliciosa:

```
1 ' OR '1'='1
```

4.
5. Se presionó el botón **Submit**.

4. Evidencia del Ataque

Al ejecutar la inyección SQL, la aplicación devolvió múltiples registros de usuarios, demostrando que la condición siempre se evalúa como verdadera y que la base de datos fue expuesta.

Figura 1. Resultado del ataque de SQL Injection mostrando la enumeración de usuarios.

5. Impacto del Incidente

La explotación de esta vulnerabilidad permite:

- Acceso no autorizado a información sensible.
- Enumeración de usuarios del sistema.
- Posible escalamiento a ataques más graves como extracción de contraseñas o modificación de datos.
  Este tipo de vulnerabilidad representa un riesgo crítico en aplicaciones reales.

6. Recomendaciones

Para mitigar este tipo de ataques se recomienda:

- Uso de **consultas preparadas (prepared statements)**.
- Validación y sanitización estricta de entradas del usuario.
- Implementación de controles de seguridad en capas.
- Uso de niveles de seguridad adecuados en entornos productivos.

7. Conclusión

El ejercicio demuestra cómo una mala gestión de entradas puede comprometer completamente la seguridad de una aplicación web.
La Inyección SQL sigue siendo una de las vulnerabilidades más peligrosas y comunes, por lo que su correcta mitigación es esencial en el desarrollo seguro de software.

Este ejercicio no solo permitió comprender la vulnerabilidad, sino también evidenciar lo sencillo que puede ser comprometer un sistema cuando no se implementan controles adecuados.

```
:\n#0 /var/www/html/DVWA/dvwa/includes/DBMS/MySQL.php(13): mysqli_connect()\n#1 /var/www/html/DVWA/setup.php(23): include_once('...')\
n#2 {main}\n  thrown in /var/www/html/DVWA/dvwa/includes/DBMS/MySQL.php on line 13, referer: http://localhost/DVWA/setup.php
[Thu Apr 02 18:32:09.406455 2026] [php:error] [pid 798:tid 798] [client 127.0.0.1:46374] PHP Fatal error:  Uncaught mysqli_sql_excepti
on: Access denied for user 'root'@'localhost' (using password: YES) in /var/www/html/DVWA/dvwa/includes/DBMS/MySQL.php:13\nStack trace
:\n#0 /var/www/html/DVWA/dvwa/includes/DBMS/MySQL.php(13): mysqli_connect()\n#1 /var/www/html/DVWA/setup.php(23): include_once('...')\
n#2 {main}\n  thrown in /var/www/html/DVWA/dvwa/includes/DBMS/MySQL.php on line 13, referer: http://localhost/DVWA/setup.php
[Thu Apr 02 18:44:31.898068 2026] [php:error] [pid 800:tid 800] [client 127.0.0.1:42008] PHP Fatal error:  Uncaught mysqli_sql_excepti
on: Access denied for user 'root'@'localhost' (using password: YES) in /var/www/html/DVWA/dvwa/includes/DBMS/MySQL.php:13\nStack trace
:\n#0 /var/www/html/DVWA/dvwa/includes/DBMS/MySQL.php(13): mysqli_connect()\n#1 /var/www/html/DVWA/setup.php(23): include_once('...')\
n#2 {main}\n  thrown in /var/www/html/DVWA/dvwa/includes/DBMS/MySQL.php on line 13, referer: http://localhost/DVWA/setup.php
[Thu Apr 02 18:51:40.873248 2026] [mpm_prefork:notice] [pid 779:tid 779] AH00170: caught SIGWINCH, shutting down gracefully
[Thu Apr 02 18:51:41.503302 2026] [mpm_prefork:notice] [pid 20873:tid 20873] AH00163: Apache/2.4.66 (Debian) OpenSSL/3.0.18 configured
 -- resuming normal operations
[Thu Apr 02 18:51:41.503410 2026] [core:notice] [pid 20873:tid 20873] AH00094: Command line: '/usr/sbin/apache2'
[Thu Apr 02 18:52:17.393674 2026] [php:error] [pid 20877:tid 20877] [client 127.0.0.1:39788] PHP Fatal error:  Uncaught mysqli_sql_exc
eption: Access denied for user 'dvwa'@'localhost' in /var/www/html/DVWA/dvwa/includes/DBMS/MySQL.php:13\nStack trace:\n#0 /var/www/htm
l/DVWA/dvwa/includes/DBMS/MySQL.php(13): mysqli_connect()\n#1 /var/www/html/DVWA/setup.php(23): include_once('...')\n#2 {main}\n  thro
wn in /var/www/html/DVWA/dvwa/includes/DBMS/MySQL.php on line 13, referer: http://localhost/DVWA/setup.php
[Thu Apr 02 18:54:17.500661 2026] [php:error] [pid 20878:tid 20878] [client 127.0.0.1:35646] PHP Fatal error:  Uncaught mysqli_sql_exc
eption: Access denied for user 'dvwa'@'localhost' in /var/www/html/DVWA/dvwa/includes/DBMS/MySQL.php:13\nStack trace:\n#0 /var/www/htm
l/DVWA/dvwa/includes/DBMS/MySQL.php(13): mysqli_connect()\n#1 /var/www/html/DVWA/setup.php(23): include_once('...')\n#2 {main}\n  thro
```